F-ADM-047-00

PEC DE México, S.A. de C.V.
Av. Mina de Guadalupe 503
Col. Puerto Interior C.P. 36275
Silao, Guanajuato, México
Tel: +52 (472) 748-9234

Política de Seguridad de la Información

Índice

Capítulo 1 Reglas generales 1

Artículo 1 Propósito 1

Artículo 2 Definición de los términos 1

Artículo 3 Ámbito de aplicación 3

Artículo 4 Objetivo de protección 3

Artículo 5 Prohibición de actividades ilegales 3

Capítulo 2 Administración del sistema 4

Artículo 6 Responsable de seguridad de la información 4

Artículo 7 Administrador de seguridad de la información 4

Artículo 8 Personal de seguridad de la información 4

Capítulo 3 Estándares de medidas de seguridad del equipo de información 6

Artículo 9 Definiciones de incidentes/accidentes de seguridad de la información 6

Artículo 10 El estándar de medidas de prevención de accidentes de seguridad de la información 6

Artículo 11 Flujo de respuesta para incidentes/accidentes de seguridad de la información 6

Artículo 12 Administrar el historial de cambios del sistema 8

Artículo 13 Seguridad de los dispositivos terminales de correo electrónico 8

Artículo 14 Protegiendo la información enviada y recibida por correo electrónico 9

Artículo 15 Protección de redes al utilizar correo electrónico 9

Artículo 16 Prevención de daño por virus vía correo electrónico 9

Artículo 17 Monitoreo de correo electrónico 10

Artículo 18 Instalación del software de antivirus 10

Artículo 19 El uso de un software antivirus 10

Artículo 20 Cuando el software antivirus detecta un virus informático 11

Artículo 21 En caso de que tu PC esté infectada con un virus informático o encuentres síntomas que parezcan indicar la presencia de un virus informático 11

Artículo 22 Prohibición del uso de equipo de información personal y equipo de información externo 12

Artículo 23 Restricciones en las funciones de las PC 12
Artículo 24 Software instalado en la PC 12
Artículo 25 Manejo de los datos de la computadora 13
Artículo 26 Reubicación de la computadora 13
Artículo 27 Sobre el uso externo de la computadora 13
Artículo 28 La devolución del equipo de información 14
Artículo 29 Reglas para los dispositivos móviles prestados por la empresa 14
Artículo 30 Seguridad de los dispositivos terminales que utilizan Internet 14
Artículo 31 Uso del internet 15
Artículo 32 Acceso a sitios web con control de acceso a la navegación. 16
Artículo 33 Recopilación de registros de uso de Internet 16
Artículo 34 Manejo de nuevos ID de usuario 16
Artículo 35 Cambiar un ID de usuario 17
Artículo 36 Eliminar un ID de usuario 17
Capítulo 4 Medidas y estándares de seguridad de redes. 18
Artículo 37 Clasificación de la red interna 18
Artículo 38 Uso de la red interna 18
Artículo 39 Al conectar a la red interna, es importante tener en cuenta los siguientes puntos 19
Artículo 40 En cuanto a la instalación de una red inalámbrica LAN 19
Artículo 41 Cambio de red interna 19
Artículo 42 Fallo del Sistema de información 19
Artículo 43 Uso de la VPN 20
Artículo 44 Operación segura de la VPN 20
Artículo 45 Recopilación de registros de uso de VPN 20
Capítulo 5 Las normas de medidas de seguridad física 21
Artículo 46 Gestión de la sala de servidor 21
Artículo 47 Gestión de tarjetas de empleado PEC 21
Artículo 48 Gestión de cerraduras eléctricas 22

Artículo 49 Reparación de equipos de información 22
Artículo 50 Uso de medios de guardado electromagnético 22
Artículo 51 Almacenamiento de medios de guardado electromagnético 22
Artículo 52 Movimiento de los medios de guardado electromagnético 23
Artículo 53 La disposición adecuada de las computadoras (PC) y los medios de guardado electromagnético 23
Artículo 54 El manejo y almacenamiento de medios de grabación electromagnética, como parte de una política de escritorio limpio (Política del Escritorio Limpio) 23
Artículo 55 Manejo de la información que se muestra en la pantalla de la PC, como parte de una política de pantalla limpia (Política de la pantalla limpia) 24
Artículo 56 El manejo adecuado de los equipos de oficina y comunicación 24
Artículo 57 La prevención de fugas de información debido a escuchas clandestinas 24
Capítulo 6 Los estándares de operación de seguridad de la información 24
Artículo 58 El estándar para el sistema de verificación interna 24
Capítulo 7 Las pautas de seguridad para trabajar desde casa 26
Artículo 59 Red y terminal a usar 26
Artículo 60 Las contramedidas contra dispositivos perdidos o robados 26
Artículo 61 Las contramedidas contra la fuga y el robo de información 26
Capítulo 8 La educación y difusión en seguridad de la información 27
Artículo 62 Implementación de la educación 27
Artículo 63 Implementación y educación de pruebas de seguridad 27
Artículo 64 Notificaciones a usuarios 27
Capítulo 9 La subcontratación de sistemas de información 28
Artículo 65 Correspondencia con empresas subcontratadas. 28
Capítulo 10 Sanciones 29
Artículo 66 Sanción 29
Capítulo 11 Reglas de excepción 30
Artículo 67 Excepción 30
Artículo 68 Fecha de entrada en vigor 30

Capítulo 1 Reglas generales

Artículo 1 Propósito

Basado en la política de seguridad de la información, la empresa tiene como objetivo obtener y mantener la confianza de la sociedad mediante la unificación de las intenciones en toda la compañía con respecto a la seguridad de la información y proteger minuciosamente los activos de información de manera apropiada.

Artículo 2 Definición de los términos

Las definiciones de términos utilizados en esta política son los siguientes.

1. Sistema de información: información, equipo e infraestructura de redes, así como hardware y software conectados a ellos.
2. Usuario: una persona que tiene permitido utilizar el sistema y la red interna, y es un oficial, empleado, trabajador a tiempo completo o parcial, contratista, asesor, persona enviada desde una empresa, o empleados enviados de la compañía a otras compañías. Incluyendo a los empleados de compañías afiliadas y clientes que utilizan temporalmente los activos de información de la empresa para trabajar.
3. Medio de almacenamiento de información electromagnético: un medio de almacenamiento de información electromagnético (cinta magnética, CD, DVD, disco duro, SSD, memoria, etc.) para almacenar datos electrónicos que se pueden retirar del equipo informático.
4. Información: información creada, recolectada, o adquirida por el usuario en el negocio de la compañía, e información grabada en el sistema informático o medio de almacenamiento de información electromagnético y la información descrita en el documento.
5. Información confidencial: información del cliente, información técnica, información del personal.
6. Servicio de información: procesamiento como buscar, editar y transmitir información.
7. Información del equipo: hardware (PC, PC de viaje de negocios, smartphone, tablet, dispositivo multifuncional, impresora) y software que almacena información y proporciona servicios de información.
8. Red: hardware como cableado, routers, concentradores, etc. Para conectar múltiples dispositivos de información para transmitir y operar información, y software como direcciones IP, protocolos y programas.

9. Red de OA (Oficina Automatizada): una red interna a la que se conecta equipo de información para trabajo de oficina, y a la que se conecta equipo de información que puede actualizar su software.
10. Red de FA (Automatización de Fábrica): una red interna a la que equipo de producción está conectada, y a la que se conecta equipo de información que no puede actualizar su software.
11. LAN (Red de Área Local): una red en el mismo edificio.
12. VPN (Red Privada Virtual): un servicio que te permite acceder a una red interna desde afuera de la compañía mediante la autenticación o encriptado de la comunicación.
13. NAS (Almacenamiento Conectado a Red): un disco de respaldo de información conectado a la red corporativa.
14. Seguridad de la información: mantener la integridad de las siguientes propiedades que la información y los sistemas de información deben tener:
    - Confidencialidad (significa que solamente las personas autorizadas pueden acceder a ella)
    - Integridad (significa que se deben proteger la precisión e integridad de la información y sus métodos de procesamiento)
    - Disponibilidad (significa que se garantiza a los usuarios autorizados acceder a la información y sistemas de información cuando lo necesiten)
15. Violación de la seguridad de la fuga de información, falsificación, destrucción, fallo, etc.
16. Outsourcer: persona que se encarga de parte de o de todo el procesamiento de información, como planificación, desarrollo, mantenimiento y operación relacionados con los sistemas informáticos.
17. Transferencia de información: la transmisión de información fuera de la compañía y transporte de equipo de información, medio de grabación electromagnética y documentos en los que la información está grabada.
18. Activos de información: información, equipo informático, redes, sistemas de información, medio de almacenamiento de información electromagnético, etc. definidos en la edición anterior.
19. User ID: número o abreviación para identificar a una persona que usa una computadora o una red. A veces es sólo números, a veces una combinación de símbolos y números, y a veces el nombre se escribe en orden alfabético. ID es una abreviación para identificación.

20. Empresa: PEC de México y PEC de América.

Artículo 3 Ámbito de aplicación

Esta regla aplica a todos los usuarios que usen los activos de información de la empresa.

Artículo 4 Objetivo de protección

El objetivo de protección de esta regla es toda la información almacenada por la compañía independientemente del medio de grabación.

Artículo 5 Prohibición de actividades ilegales

Prohibido el uso de equipo y redes de información interna con el propósito de ataques cibernéticos u otras actividades ilegales.

Capítulo 2 Administración del sistema

Artículo 6 Responsable de seguridad de la información

1. La empresa tiene un responsable de seguridad de la información.
2. La persona a cargo del responsable de seguridad de la información será el Presidente.
3. El responsable de la seguridad de la información tiene la autoridad y responsabilidad de tomar la decisión final en la seguridad de la información de la empresa.

Artículo 7 Administrador de seguridad de la información

1. La empresa tiene un administrador de seguridad de la información.
2. El administrador de seguridad de la información debe ser del equipo de HR/GA/IT.
3. El administrador de seguridad de la información tiene los siguientes roles y autoridad.
   - Mantener y gestionar la seguridad de la información relacionada al sistema de información de la empresa.
   - Como medida preventiva para incidentes que puedan causar daños a la empresa, el administrador de información tiene la autoridad para suspender, según sea necesario, el uso de computadoras y redes del usuario correspondiente.
   - Considerando la gestión y mejora de la eficiencia de los sistemas de computadoras y redes, proponer información y opiniones relevantes a la administración.

Artículo 8 Personal de seguridad de la información

1. La empresa tiene personal de seguridad de la información.
2. El personal de seguridad de la información será designado por el responsable de la seguridad de la información a partir del equipo de HR/GA/IT.
3. El personal de seguridad de la información tiene los siguientes roles y autoridad.
   - Implementar medidas de seguridad de la información basadas en las instrucciones del responsable de seguridad de la información o del administrador de seguridad de la información.
   - Monitorear que los usuarios estén haciendo uso de las computadoras y redes de manera correcta.
   - Si se detecta una violación basada en la disciplina de computadoras y redes estipulada en esta norma, el administrador de seguridad de la información deberá ser notificado inmediatamente.
   - Establecer los derechos de acceso a los sistemas, sistemas de cifrado automatizados, software e instalaciones de equipos relacionados con

computadoras y redes, y mantenerlos de manera que puedan ser utilizados en todo momento.

- No acceder a una computadora a la que no tengan acceso como parte de su autoridad laboral. Además, no se debe divulgar la información obtenida de la empresa.
- Si la computadora de un usuario contiene datos que puedan causar una falla en la red, es necesario contactar inmediatamente al administrador de seguridad de la información.

Capítulo 3 Estándares de medidas de seguridad del equipo de información

Artículo 9 Definiciones de incidentes/accidentes de seguridad de la información

El alcance de los incidentes/accidentes de seguridad de la información es de la siguiente manera.

1. Robo o pérdida de la computadora, medios de almacenamiento de información electromagnética, o medios de papel que contienen información confidencial.
2. El ataque de programas maliciosos (infección de malware, acceso no autorizado, falsificación del sitio web de la empresa, toma de control de PC, entre otros).
3. La transmisión incorrecta de información confidencial por correo electrónico, fax, correo postal (incluyendo EMS).
4. La filtración de información confidencial por parte de subcontratistas.
5. La filtración de información confidencial a terceros cuando el usuario es consciente de que se maneja como confidencial.
6. Otros eventos que pueden conducir o contribuir a la filtración de información y que son considerados importantes por el responsable de seguridad de la información.

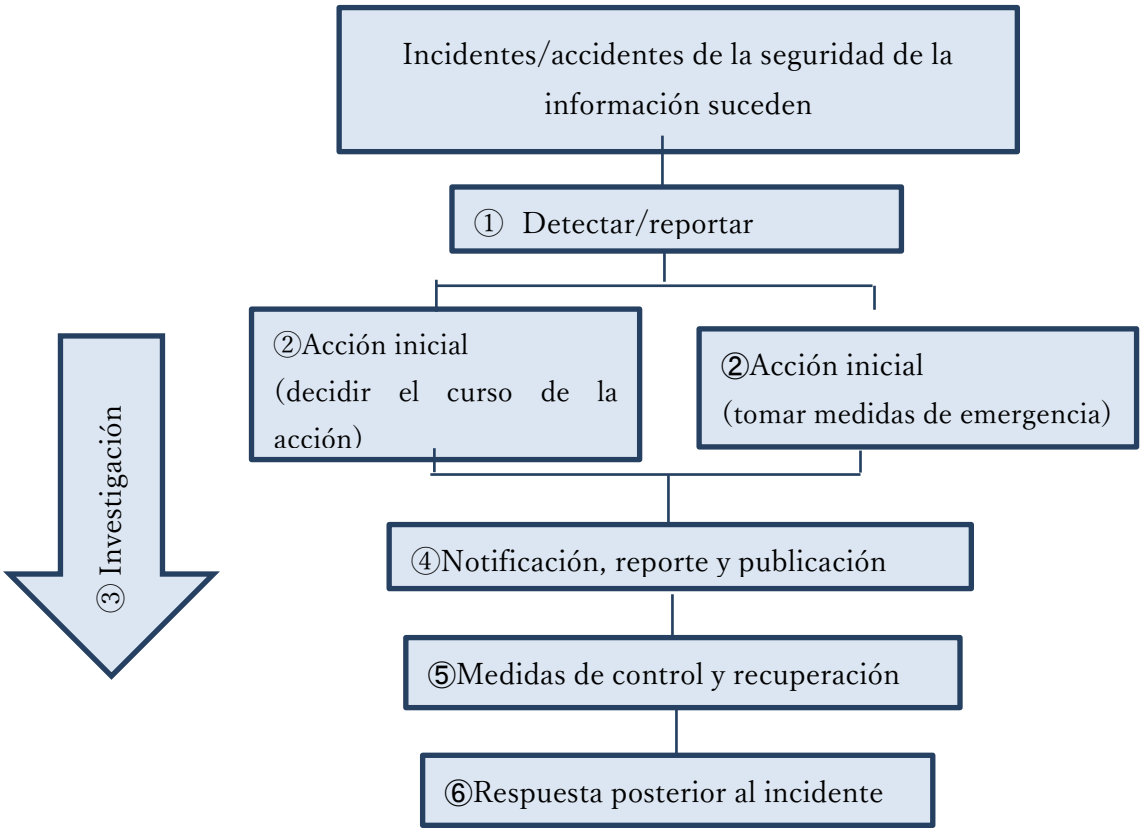
Artículo 10 El estándar de medidas de prevención de accidentes de seguridad de la información

1. Es responsabilidad del administrador de seguridad de la información trabajar para implementar un sistema que refleje medidas efectivas para prevenir brechas de seguridad de la información.
2. Si un usuario descubre un accidente relacionado con la seguridad de la información o un defecto en el sistema, el usuario no debe resolver el accidente o defecto de forma independiente. En su lugar, debe informar inmediatamente al personal de seguridad de la información para resolver los accidentes y defectos de seguridad de la información.

Artículo 11 Flujo de respuesta para incidentes/accidentes de seguridad de la información

El personal de seguridad de la información debe seguir los siguientes procedimientos cuando ocurre un incidente o accidente de seguridad de información.

Flujo de respuesta para incidentes/accidentes de seguridad de la información



① Detectar/reportar

Si hay algún hecho o suposición de que ha ocurrido algún incidente o accidente de la información de la seguridad, repórtalo al personal de la seguridad de información. El personal de la seguridad de la información reporta al administrador de la seguridad de la información y al responsable de la seguridad de la información.

② Acción inicial

Investigar la situación de los incidentes/accidentes de seguridad de información, posicionar su importancia y determinar contramedidas. Además, tomar medidas de emergencia necesarias para evitar que el daño se propague. (Ej. Desconectar dispositivos como servidores de la red, etc.)

③ Investigación

Investigar los hechos respecto a los incidentes y accidentes de seguridad de la información. Investigar hechos y organizar la información desde una perspectiva de 5WIH (cuándo, dónde, quién, cómo, por qué) para responder apropiadamente. Los elementos de investigación incluyen la escala, alcance, duración, antecedentes que llevaron al incidente/accidente de seguridad de la información, causas y daños

(incluidos los daños debido a la divulgación de información confidencial). Utilice software de gestión de clientes, etc., y recopile información que sirva como evidencia. Tenga cuidado con el comportamiento arriesgado que borra datos al investigar la evidencia.

a. Error de juicio o de operación por parte de la persona encargada
b. Operaciones por parte de usuarios no involucrados en la respuesta a incidentes
c. Pérdida de datos debido a la activación de la trampa establecida por el atacante

④ Notificar, reportar, publicar

Implementar procesos para dar a conocer los hechos a los interesados respecto lo que ocurre con los incidentes y accidentes, y el estado de la respuesta de la organización. En caso de filtración de información (incluyendo posibilidad de filtración) y si hay un alto riesgo de dañar los derechos e intereses de un individuo, reportar al administrador de la seguridad de la información y notificar al individuo.

⑤ Medidas de control y recuperación

Para prevenir que se propague el daño y recuperarnos de él, si hay una vulnerabilidad en la seguridad de la información, tomar contramedidas y restaurar el sistema. Si hay información importante dañada, restaurarla desde el respaldo, y si hay un problema con la línea de Internet, tomar medidas así como cambiarse a la línea proporcionada para BCP (Plan de Continuidad del Negocio).

⑥ Respuesta posterior al incidente

Considerar e implementar medidas fundamentales para prevenir la recurrencia. Además, crear reportes de investigación sobre los incidentes y accidentes de la seguridad de la información.

Artículo 12 Administrar el historial de cambios del sistema

El personal de la seguridad de la información administra el historial de cambios en cada sistema.

Artículo 13 Seguridad de los dispositivos terminales de correo electrónico

1. Al enviar y recibir correos electrónicos, debes usar el software de correo electrónico especificado por la empresa.
2. Las contraseñas del correo electrónico deben ser cambiadas regularmente una vez cada tres meses.
3. Sin embargo, esto no aplica si el departamento de HR/GA/IT asigna una contraseña compleja de 10 dígitos o más y no la divulga al usuario. En ese caso, si la contraseña de inicio de sesión de la computadora y la contraseña del correo electrónico son la misma,

el inicio de sesión en la computadora debe ser realizado por medio de autenticación biométrica o código PIN.

Artículo 14 Protegiendo la información enviada y recibida por correo electrónico

1. En un principio, la información confidencial tal como información relacionada al negocio de la compañía e información relacionada a la privacidad de clientes e individuos no debe ser enviada fuera de la empresa usando correo electrónico.
2. Antes de enviar un correo electrónico, debes confirmar que la dirección de correo electrónico del destinatario es correcta.
3. Cuando envíes un correo electrónico con un archivo adjunto al exterior, con la aprobación del supervisor directo, cifra el archivo adjunto, agrega una contraseña y envíalo. La contraseña se enviará por otro correo electrónico. Además, se operará para que el supervisor directo esté en copia (cc).

Artículo 15 Protección de redes al utilizar correo electrónico

1. El personal de la seguridad de la información debe habilitar la función de bloqueo de correo no deseado del servidor de correo electrónico.
2. Si recibes un correo electrónico sospechoso, no lo reenvíe. Y elimínalo de inmediato.
3. Al enviar un correo electrónico, debes considerar el tamaño del correo electrónico. El tamaño total de un correo electrónico es de 20MB. Si no tienes opción más que enviar un correo electrónico más grande que el tamaño indicado anteriormente, divide los archivos adjuntos.
4. No utilices el correo electrónico para ningún otro propósito que no sea el de negocios.
5. No sobrecargues la red enviando y recibiendo correos electrónicos inservibles.
6. Los correos electrónicos enviados en formato HTML no deben ser enviados para ser mostrados automáticamente.

Artículo 16 Prevención de daño por virus vía correo electrónico

1. El personal de seguridad de la información debe habilitar la función de protección de correo de virus en el servidor de correo electrónico.
2. Para los adjuntos sospechosos, como archivos adjuntos a correos electrónicos de remitentes desconocidos o archivos adjuntos en formato ejecutable, eliminarlos de

inmediato sin realizar ninguna operación.

3. Si encuentra un virus o algún síntoma que parezca ser un virus mientras utiliza el servicio de correo electrónico, debe desconectar inmediatamente la LAN cableada o cambiar al modo avión para desconectarse de la red interna y contactar al personal de seguridad de la información.
4. Con el propósito de evitar propagar el virus informático por correo electrónico, cuando reenvíes un correo electrónico recibido de otro dominio que no sea pec-am.com, la razón por la que se reenvía debe estar claramente mencionada en el texto.

Artículo 17 Monitoreo de correo electrónico

1. Los usuarios deben entender que el estatus del uso del correo electrónico es monitoreado por la empresa.
2. El cuerpo del correo electrónico debe ser guardado en un medio que pueda ser restaurado durante un año después de enviar y recibir
3. Correos electrónicos relevantes estipulados por la ley Mexicana serán archivados por 10 años.

Artículo 18 Instalación del software de antivirus

1. El personal de la seguridad de la información instalará el software de antivirus en todas las computadoras y servidores conectados a la red de OA.
2. Los requerimientos para que el software de antivirus sea seleccionado deben incluir las siguientes funciones:
    - Función de actualización automática de archivos de definición
    - Función de monitoreo en tiempo real
3. El personal de seguridad de la información instalará el software antivirus especificado en la PC y el servidor, y se instalará después de realizar la siguiente configuración.
    - Realizar una verificación de virus en todos los archivos una vez a la semana.
    - Configurar la actualización del archivo de definiciones una vez al día.

Artículo 19 El uso de un software antivirus

El usuario no debe cambiar o eliminar la configuración del software antivirus instalado en la PC sin la instrucción del administrador de seguridad de la información.

Artículo 20 Cuando el software antivirus detecta un virus informático

1. El usuario desconecta inmediatamente la LAN cableada o cambia al modo avión para desconectarse de la red interna, informa el mensaje que se muestra en el software antivirus al personal de seguridad de la información y consulta sobre las medidas de seguridad.
2. El personal de seguridad de la información que recibe el contacto confirma que la PC está desconectada de la red interna, luego informa al administrador de seguridad de la información y notifica al usuario sobre el método de acción para hacer frente al virus.

Artículo 21 En caso de que tu PC esté infectada con un virus informático o encuentres síntomas que parezcan indicar la presencia de un virus informático

1. Cuando ocurran los siguientes síntomas, el usuario puede desconectar inmediatamente la LAN cableada o cambiar al modo avión para desconectarse de la red interna.
    - Reporta el síntoma al personal de seguridad informática y pregunta sobre cómo abordar la situación.
        - La operación de la PC se ha vuelto lenta o pesada.
        - Se ha informado que se envió un correo electrónico con un virus informático.
        - Se han observado movimientos inusuales, como fuegos artificiales y remolinos que aparecen repentinamente en la pantalla de la PC.
        - Cuando se intentó abrir el archivo, apareció una ventana emergente de advertencia de macro. (Si sabes lo que la ventana emergente significa, no tienes que reportarlo)
        - Incluso si los síntomas anteriores no se aplican, si encuentras alguna anomalía en el manejo de tu PC, es importante informarlo de inmediato al personal de seguridad de la información y preguntar cómo abordar la situación.
2. El personal de seguridad de la información que ha sido contactado debe informar al administrador de seguridad de la información después de confirmar que la PC está desconectada de la red interna, y debe dirigirse rápidamente al lugar afectado.
3. En el lugar, es necesario verificar si el archivo de definiciones del software antivirus está actualizado y, si está actualizado, ejecutar una verificación de virus en todos los archivos y comprobar si se detecta un virus informático.
4. Cuando se detecta un virus informático, es necesario realizar una investigación para determinar qué tipo de operaciones realizará debido a las características específicas del virus y especificar el rango de daño.

5. Si no se detecta un virus informático, es importante identificar la causa del problema mediante la verificación de los registros del servidor de distribución del software antivirus.
6. Cuando se produce un daño causado por un virus informático, es necesario realizar una verificación de virus en todas las PC y servidores conectados a la red relacionada.

Artículo 22 Prohibición del uso de equipo de información personal y equipo de información externo

1. El equipo de información que los usuarios pueden utilizar en las operaciones comerciales de la empresa se limita al equipo de información prestado por la propia compañía.
2. No conectar dispositivos de información personal a la red de la empresa.
3. No tomar fotografías de las instalaciones con dispositivos de información personal.
4. No conectar dispositivos de información personal a los equipos de información de la empresa.
5. En un principio, no se deben conectar dispositivos de información externos, como los de los socios comerciales, a la red interna de la empresa. Sin embargo, si resulta inevitable conectar un dispositivo de información externo a la red de la empresa, por ejemplo, en caso de una falla del sistema, se debe obtener el permiso del administrador de seguridad de la información y permitir la conexión en presencia del personal de seguridad de la información.

Artículo 23 Restricciones en las funciones de las PC

El personal de seguridad de la información debe desactivar las funciones innecesarias en el equipo de información prestado a los usuarios. Además, se debe revisar al menos dos veces al año la función a deshabilitar y configurarla en el equipo de información prestado según sea necesario.

Artículo 24 Software instalado en la PC

1. El software que se muestra en la tabla a continuación debe ser instalado en la PC alquilada por la empresa, y no se debe instalar ningún otro software sin permiso.

Software	Usuarios

Pec System (Sistema Interno)	Todos los usuarios.
Tress System (Nóminas)	Usuarios autorizados por el gerente.
Infor(ERP)	Usuarios autorizados por el gerente.
Microsoft Office	Todos los usuarios.
SolidWorks (CAD)	Usuarios autorizados por el gerente.
AutoCAD (CAD)	Usuarios autorizados por el gerente.
CATIA (CAD)	Usuarios autorizados por el gerente.
EDI (electronic data interchange)	Ventas
Acrobat Reader	Todos los usuarios.
Acrobat Standard	Usuarios autorizados por el gerente.
Sonicwall Global VPN Client	Usuarios autorizados por el gerente.

2. Para cualquier otro software que no esté especificado anteriormente y que deba ser instalado con fines comerciales, se debe solicitar la información al administrador de seguridad a través del gerente del departamento al que pertenece.
3. El personal de seguridad de la información debe recopilar información sobre el software periódicamente y aplicar parches según sea necesario.
4. El personal de seguridad de la información debe realizar un inventario de los sistemas de información externos utilizados al menos una vez al año y reflejar los sistemas nuevos o descontinuados en la lista.

Artículo 25 Manejo de los datos de la computadora

El usuario debe organizar los datos almacenados en la PC que se le ha prestado una vez al mes y eliminar los datos innecesarios.

Artículo 26 Reubicación de la computadora

1. El usuario no debe reubicar la PC administrada por el equipo de HR/GA/IT sin permiso.
2. Si es necesario reubicar la PC, es importante informar al administrador de seguridad a través del gerente del departamento para obtener el permiso correspondiente.

Artículo 27 Sobre el uso externo de la computadora

1. Cuando llevas tu computadora fuera de la oficina, es importante tener cuidado para evitar el robo y extravío.
2. Cuando utilices una computadora fuera de la empresa, debes tener cuidado para

proteger tu información y evitar que sea espiada.

3. Si deseas llevar tu PC fuera de la empresa, es necesario obtener la aprobación del gerente de tu departamento.
4. Si llevas tu PC fuera de la oficina, es importante tomar medidas para evitar que alguien más pueda conectarse a un medio de grabación electromagnética antes de sacarla.
5. Si llevas tu PC fuera de la oficina, es altamente recomendable encriptar el disco duro o la unidad de estado sólido (SSD) que se encuentra en su interior antes de sacarla.

Artículo 28 La devolución del equipo de información

1. Si el dispositivo de información ya no es necesario debido a la jubilación o transferencia, es importante devolver el dispositivo de información al personal de seguridad de la información en el último día de uso
2. En caso de no poder completar la transferencia de datos a otros usuarios, el dispositivo debe ser devuelto al departamento de IT dentro de los 5 días hábiles posteriores a la terminación del empleado.

Artículo 29 Reglas para los dispositivos móviles prestados por la empresa

1. El usuario no debe instalar aplicaciones que no estén relacionadas con el negocio en el dispositivo móvil prestado por la empresa.
2. El usuario no debe cargar los datos del dispositivo móvil en una red que pueda ser accesible para uso privado.
3. Los gerentes están obligados a llevar consigo un smartphone proporcionado por la empresa en todo momento, incluso fuera del horario laboral, como preparación para emergencias.
4. Si el dispositivo móvil se pierde o se daña, es importante informarlo de inmediato al administrador de seguridad de la información. Además, el usuario debe entender que en caso de pérdida del dispositivo móvil, la información de ubicación del dispositivo será verificada por la empresa.
5. Como norma general, se recomienda utilizar la autenticación biométrica para iniciar sesión en los dispositivos y establecer una contraseña que sea difícil de identificar.

Artículo 30 Seguridad de los dispositivos terminales que utilizan Internet

1. Cuando se utiliza Internet, el usuario debe utilizar el navegador de Internet instalado por el personal de seguridad de la información y no instalar otro navegador

sin permiso. Además, la versión del software debe actualizarse y aplicar los parches de seguridad de acuerdo con las instrucciones del personal de seguridad de la información.

2. El personal de seguridad de la información debe instalar los ajustes internos estándar en el navegador de Internet designado después de implementarlos, y el usuario no debe cambiar la configuración sin permiso.

Artículo 31 Uso del internet

1. Los usuarios solo pueden acceder a Internet cuando sea necesario para sus actividades laborales.
2. Antes de acceder a un sitio web al hacer clic en un enlace, el usuario debe confirmar el nombre de destino del enlace.
3. Si el nombre del enlace no es confiable, no se debe acceder al sitio. Lo mismo se aplica a los anuncios en forma de banner, y los banners que no sean necesarios para el negocio no deben ser accedidos en el sitio.
4. El usuario no debe descargar archivos, software o archivos sospechosos que no sean necesarios para el negocio.
5. El usuario no debe ejecutar código como ActiveX o Java desde un sitio no confiable.
6. Los usuarios no deben realizar accesos no autorizados a servidores de Internet dentro o fuera de la empresa, como ataques cibernéticos. Además, no deben utilizar sistemas internos o externos con el propósito de acceder sin autorización.
7. El usuario no debe escribir la información que ha aprendido en el transcurso del negocio en el tablón de anuncios de Internet. Sin embargo, si el gerente del departamento admite que es necesario para el negocio, está permitido.
8. En este momento, se debe garantizar la precisión de la información y transmitirla dentro del rango mínimo necesario. Además, se prohíbe la transmisión de información correspondiente a lo siguiente.
9. Lo mismo se aplica a la información de navegación.
    - Elementos que puedan infringir derechos de autor, marcas comerciales y derechos de retrato.
    - Elementos que puedan invadir la privacidad.
    - Problemas relacionados con la evaluación social de otras personas.
    - Cosas que puedan dañar el honor y la credibilidad de otras personas.
    - Elementos que puedan dañar el crédito y la dignidad de la empresa.
    - Cosas que puedan promover el acceso no autorizado.
    - Discriminatorio.

- Cosas falsas.
- Información confidencial dentro de la empresa.
- Otros elementos que puedan ofender el orden público y la moral.

Artículo 32 Acceso a sitios web con control de acceso a la navegación.

1. El usuario no debe almacenar la contraseña en el almacenamiento de un servidor externo o un servidor en la nube al navegar por sitios web, como WEB-EDI, cuyo acceso está controlado por contraseña.
2. El usuario debe cerrar el navegador de Internet al abandonar el puesto cuando esté navegando en un sitio web con control de acceso a Internet.
3. El usuario no debe utilizar el ID de usuario o la contraseña de otra persona para acceder a un sitio web con control de acceso a Internet.

Artículo 33 Recopilación de registros de uso de Internet

1. El personal de seguridad de la información debe recopilar siempre los registros de uso de Internet, y se debe establecer un sistema para rastrearlos.
2. El personal de seguridad de la información verifica el registro de uso de Internet al investigar la detección de virus relacionados con el sitio web, y si encuentra acceso, como la navegación en un sitio web que no es necesario para el negocio o el uso indebido de Internet, debe informar al gerente del departamento y al oficial de seguridad de la información.

Artículo 34 Manejo de nuevos ID de usuario

1. Cuando se requiere un nuevo ID de usuario, el tipo de ID de usuario requerido y la autoridad correspondiente se proporcionan al administrador de seguridad de la información a través del gerente del departamento. En este caso, se utiliza la solicitud de instalación de software / solicitud de ID de usuario para realizar la solicitud.
2. El administrador de seguridad de la información que recibió la solicitud examina la autoridad y necesidad necesarias, y si determina que es apropiado, instruye al personal de seguridad de la información para que emita un nuevo ID de usuario.
3. El personal de seguridad de la información debe establecer una autoridad de acceso y una contraseña adecuada para el ID de usuario.
4. En relación a la autoridad de acceso, como correo electrónico, Internet, sistema de producción, etc., se creará y gestionará una tabla de autoridad de acceso.

5. El usuario no debe utilizar el sistema de información con el ID de usuario de otra persona.

Artículo 35 Cambiar un ID de usuario

Cuando se realiza un cambio en la autoridad asignada a un ID de usuario, el formulario de solicitud de instalación de software / ID de usuario se envía al administrador de seguridad de la información a través del gerente del departamento.

Artículo 36 Eliminar un ID de usuario

1. Cuando la persona encargada del personal recibe información de que un ID de usuario ya no es necesario debido a la jubilación o ausencia, debe notificar inmediatamente al administrador de seguridad de la información y eliminar/suspender el ID de usuario.
2. Cuando se borra un ID de usuario del correo electrónico, el personal de seguridad de la información, al recibir la notificación, confirmará con el gerente del departamento al que pertenece el usuario. Después de la confirmación, se tomarán medidas, como reenviar los correos electrónicos que lleguen a la persona correspondiente.
3. Si se requiere el reenvío de correos electrónicos, el personal de seguridad de la información configurará el reenvío durante un período de un mes como principio general. Posteriormente, se eliminará el ID de usuario.

Capítulo 4 Medidas y estándares de seguridad de redes.

Artículo 37 Clasificación de la red interna

1. Los dispositivos de información que no pueden actualizar el sistema operativo o el software no deben estar conectados a Internet ni a la red OA.
2. La red OA y la red FA estarán separadas de modo que los equipos de información de la red FA no puedan acceder a los equipos de información de la red OA.
3. El cable de LAN será codificado por colores de acuerdo con su propósito de la siguiente manera, para poder identificar su uso previsto:
    - Azul — Red OA (Oficina Administrativa)
    - Blanco — Red FA (Fábrica Automatizada)
    - Amarillo — Red local individual
    - Rojo — Conexión telefónica de línea fija

Artículo 38 Uso de la red interna

1. Cuando se requiere una nueva conexión de red interna para una PC, o cuando deja de ser necesaria, el usuario proporciona la siguiente información al administrador de seguridad de la información a través del jefe del departamento al que pertenece. Debe solicitarlo utilizando el formulario de solicitud de instalación de PC y obtener la aprobación.
2. Nombre de usuario
3. Propósito de uso.
4. Especificaciones de la PC.
5. Sistema a utilizar.
6. The information security staff determines the user ID, password and IP address when the user's application for in-house network connection of the PC is approved.
7. El personal de seguridad de la información debe gestionar y guardar la siguiente información con respecto a las PC e impresoras conectadas a la red de la empresa:
    - Número de control
    - Nombre del fabricante
    - Nombre y número de modelo
    - Fecha de compra
    - Especificaciones técnicas
    - Nombre de usuario (solo para computadora)
    - ID de usuario (solo para computadora)

- Dirección de correo electrónico (solo cuando sea necesario)
- Nombre de la PC o impresora.
- Contraseña (solo para computadora)
- Dirección IP
- Software de instalación (solo para computadora)
- Ubicación de instalación

Artículo 39 Al conectar a la red interna, es importante tener en cuenta los siguientes puntos

1. El usuario no debe cambiar la estructura de red de la red gestionada por los equipos de HR/GA/IT instalando un switch HUB sin permiso del equipo de RH/GA/TI.

Artículo 40 En cuanto a la instalación de una red inalámbrica LAN

1. El oficial de seguridad de la información decidirá si instalar o no un enrutador WiFi.
2. Al construir una red inalámbrica LAN, el personal de seguridad de la información debe construirla utilizando configuraciones de autenticación y encriptación de terminales.

Artículo 41 Cambio de red interna

1. Si el propósito o la forma de uso de una PC o impresora conectada a la red interna alquilada de la empresa cambia, el usuario debe solicitar de inmediato la siguiente información al administrador de seguridad de la información
    - Nombre de usuario
    - Propósito del cambio
    - Cambio en la ubicación
    - Change date and time
2. El administrador de seguridad de la información debe confirmar los cambios y notificar al usuario si los cambios son posibles o no.
3. El personal de seguridad de la información debe actualizar la información gestionada una vez que se aprueben los cambios.
4. El personal de seguridad de la información debe presenciar la fecha y hora del cambio para confirmar que no haya problemas con el trabajo de cambio.

Artículo 42 Fallo del Sistema de información

Si un usuario provoca o descubre una falla en el sistema que afecta a los departamentos o a toda

la empresa, se debe presentar un informe de daños en las instalaciones y daños/pérdidas de equipos al oficial de seguridad de la información.

Artículo 43 Uso de la VPN

1. Los usuarios pueden acceder a la red interna utilizando una PC de viaje de negocios o una PC alquilada por la empresa fuera de las instalaciones y utilizando una VPN.
2. El personal de seguridad de la información debe configurar la función de autenticación requerida para la conexión VPN.
3. El usuario debe utilizar software antivirus, asegurarse de actualizar los archivos de definición y realizar un escaneo de virus en todos los archivos antes de conectarse a la VPN con una PC de viaje de negocios o una PC alquilada.
4. El usuario no debe dejar la PC de viaje de negocios o la PC alquilada por la empresa sin supervisión mientras está conectado a la VPN.
5. Si el usuario pierde o le roban una PC de viaje de negocios, un PC, un teléfono inteligente o una tableta alquilada por la empresa, debe informarlo de inmediato al administrador de seguridad de la información.

Artículo 44 Operación segura de la VPN

El personal de seguridad de la información debe confirmar que el archivo de definición del software antivirus esté actualizado antes de utilizar la PC para viajes de negocios, y luego realizar un análisis de virus en todos los archivos. Al mismo tiempo, debe verificar la existencia de software y archivos innecesarios.

Artículo 45 Recopilación de registros de uso de VPN

1. La VPN recopilará registros, y en caso de que ocurra algún problema, debe existir un sistema para rastrearlo.

El registro debe contener los siguientes elementos:

- Acceso exitoso, fecha y hora de fallos
- USER ID

Capítulo 5 Las normas de medidas de seguridad física

Artículo 46 Gestión de la sala de servidor

1. La sala de servidores debe ser un espacio independiente y no debe ser compartida con otras oficinas.
2. Instalar la sala de servidores lejos de lugares con alto riesgo de desastres, como áreas de almacenamiento de materiales peligrosos, instalaciones contra incendios y instalaciones de suministro de agua.
3. La sala de servidores siempre debe estar cerrada con llave, y la llave debe ser custodiada por el gerente de seguridad de la información y el oficial de seguridad de la información. Solo las personas autorizadas pueden ingresar.
4. El personal de seguridad de la información debe controlar adecuadamente la temperatura y la humedad en la sala de servidores.
5. Instalar un extintor de incendios en la sala de servidores o en un lugar visible inmediatamente después de salir de la sala de servidores.
6. No se deben instalar equipos para copiar o transmitir información, como copiadoras o fax, en la sala de servidores..
7. No se debe fotografiar ni grabar en la sala de servidores sin el permiso del administrador de seguridad de la información.
8. Cuando un contratista externo trabaje en la sala de servidores, el personal de seguridad de la información debe estar presente y el contratista externo no debe trabajar solo.
9. Cuando un contratista externo utilice el sistema interno, se debe obtener el permiso del personal de seguridad de la información.

Artículo 47 Gestión de tarjetas de empleado PEC

1. La tarjeta de empleado PEC será prestada por la empresa al usuario en el momento de unirse a la compañía, y el usuario la devolverá a la empresa en el momento de su retiro.
2. La tarjeta de empleado PEC se utiliza para fichar en el reloj de tiempo del sistema de trabajo. Nunca se debe transferir o prestar a otra persona..
3. Si se pierde o se daña la tarjeta de empleado PEC, el usuario debe ponerse en contacto de inmediato con la persona responsable del equipo de recursos humanos para solicitar la reemisión de la tarjeta.

Artículo 48 Gestión de cerraduras eléctricas

1. El administrador de seguridad de la información solicita al equipo de RH/GA/IT encargado de la gestión de las cerraduras eléctricas que instalen cerraduras eléctricas en las entradas y salidas que requieren restricciones de entrada/salida a las habitaciones.
2. El personal de seguridad de la información confirma que se elimina el ID de usuario de la cerradura eléctrica el día de la jubilación del usuario.

Artículo 49 Reparación de equipos de información

1. Al solicitar la reparación de equipos de información a un contratista, el personal de seguridad de la información debe confirmar que la información altamente confidencial no se encuentra almacenada de forma legible antes de solicitar la reparación. (Excepto cuando la información almacenada no pueda ser confirmada o protegida debido a la situación de falla).
2. Durante la reparación de equipos de información, el personal de seguridad de la información debe preparar un dispositivo sustituto y alquilarlo según sea necesario.
3. Si es necesario restaurar los datos, se debe solicitar la reparación después de firmar un acuerdo de confidencialidad con el contratista.

Artículo 50 Uso de medios de guardado electromagnético

1. Se prohíbe llevar medios de grabación electromagnética personales al interior de la empresa o sacar los medios de grabación electromagnética propiedad de la empresa fuera de la misma. Esta medida busca evitar la filtración o pérdida de datos confidenciales o propietarios.
2. Cuando se utilizan medios de grabación electromagnética para transferir datos de manera temporal, se debe eliminar la información almacenada en ellos cada vez que se realice la transferencia. Además, antes de devolver los medios, es importante asegurarse de que los datos hayan sido eliminados de manera segura para evitar cualquier posible acceso no autorizado.

Artículo 51 Almacenamiento de medios de guardado electromagnético

Las personas que almacenan información altamente confidencial, como información de clientes y datos personales, en medios de grabación electromagnética deben implementar medidas de seguridad adicionales para proteger la información almacenada. A continuación, se presentan algunas recomendaciones:

El medio de grabación electromagnética debe ser almacenado en un lugar cerrado con llave, y

la gestión de las llaves debe ser responsabilidad de la persona autorizada para manejar la información.

Artículo 52 Movimiento de los medios de guardado electromagnético

En principio, está prohibido enviar medios de grabación electromagnética que contengan información altamente confidencial utilizando una empresa de mensajería.
Si es necesario por motivos de negocios, deberá enviarse utilizando medios que garanticen la seguridad después de obtener el permiso del presidente.

Artículo 53 La disposición adecuada de las computadoras (PC) y los medios de guardado electromagnético

1. El personal de seguridad de la información de puede deshacerse de las computadoras o medios de guardado electromagnético.
2. Extraer físicamente el disco duro o SSD de la PC para evitar cualquier posibilidad de recuperación de datos.
3. Destruir el medio de grabación electromagnética de manera irreversible y en un estado no reproducible. Esto puede incluir métodos como la trituración, el aplastamiento o la incineración, que garantizan que la información almacenada no pueda ser recuperada.
4. Contratación de servicios externos: Si el personal de seguridad de la información subcontrata la disposición de las PC y los medios de grabación electromagnética a un contratista externo, el contrato debe incluir disposiciones relacionadas con la confidencialidad. Esto garantiza que el contratista cumpla con los estándares de seguridad

Artículo 54 El manejo y almacenamiento de medios de grabación electromagnética, como parte de una política de escritorio limpio (Política del Escritorio Limpio)

1. El usuario debe almacenar los medios de grabación electromagnética no utilizados en un armario u otro lugar seguro, y no dejarlos en el escritorio.
2. El usuario debe almacenar los medios de grabación electromagnética no utilizados en un armario u otro lugar seguro, y no dejarlos en el escritorio.

Artículo 55 Manejo de la información que se muestra en la pantalla de la PC, como parte de una política de pantalla limpia (Política de la pantalla limpia)

Para evitar operaciones no autorizadas y espionaje cuando se deja el escritorio, la pantalla de la PC se bloqueará automáticamente en un plazo de 5 minutos después de detener la actividad. Es importante que el usuario no cambie esta configuración.

Artículo 56 El manejo adecuado de los equipos de oficina y comunicación

1. El usuario no debe borrar el contenido escrito en la pizarra después de su uso y dejarla sin supervisión.
2. El usuario no debe dejar documentos de entrada / salida en dispositivos como multifuncionales e impresoras. Para documentos especialmente importantes, el usuario debe estar presente en todo momento en el dispositivo durante la impresión y el envío / recepción.
3. El usuario debe confirmar el destino al enviar un fax para evitar transmisiones erróneas.

Artículo 57 La prevención de fugas de información debido a escuchas clandestinas

Los usuarios deben tomar precauciones para evitar escuchas clandestinas en llamadas telefónicas, conversaciones en pie y comentarios en espacios de conferencia abiertos.

Capítulo 6 Los estándares de operación de seguridad de la información

Artículo 58 El estándar para el sistema de verificación interna

El administrador de seguridad de la información debe establecer un sistema para verificar el estado de operación del software relacionado con la seguridad y asegurarse de que el usuario

pueda operar de acuerdo con esta regla para los siguientes elementos:

- Operación de correo electrónico.
- Operación de memoria USB.
- Operación de respaldo de correo (cuando se utiliza el servidor de la empresa).
- Estado de funcionamiento de la cerradura eléctrica.
- Estado de funcionamiento del software antivirus.
- Estado de funcionamiento de la VPN.

Capítulo 7 Las pautas de seguridad para trabajar desde casa

Artículo 59 Red y terminal a usar

1. Cuando trabajas desde casa, debes solicitar el uso de la aplicación de PEC System [Formulario de solicitud de teletrabajo] para obtener una computadora portátil para trabajar desde casa y obtener la aprobación del gerente al que perteneces.
2. En principio, el terminal utilizado para trabajar desde casa no debe ser utilizado fuera del hogar. Sin embargo, si debido a circunstancias inevitables, tienes que trabajar en un lugar que no sea tu hogar, como un hotel, puedes usarlo fuera de tu hogar con la aprobación del gerente de tu departamento.
3. Utiliza tu entorno de red doméstica o un enrutador móvil proporcionado por tu empresa para conectarte a la red. Si trabajas fuera de tu hogar, como en un hotel, debido a circunstancias inevitables, solo puedes conectarte a una red Wi-Fi que esté asegurada con contraseña y cifrado.

Artículo 60 Las contramedidas contra dispositivos perdidos o robados

Cuando lleves contigo un terminal utilizado para trabajar desde casa, regresa directamente a tu hogar para evitar que el terminal sea robado y guárdalo en un lugar donde no pueda ser invadido desde el exterior.

Artículo 61 Las contramedidas contra la fuga y el robo de información

1. Al trabajar en un entorno compartido con terceros, es importante seleccionar un lugar de trabajo que evite la posibilidad de miradas indiscretas a la pantalla.
2. Si necesitas alejarte del terminal utilizado para el trabajo remoto desde casa, asegúrate de bloquearlo poniéndolo en modo de suspensión para que terceros no puedan ver la información.
3. No conectes la computadora proporcionada por la empresa a una impresora o dispositivo de información de propiedad privada.
4. Además, la información relacionada con el trabajo no debe ser transmitida por ningún otro método.

Capítulo 8 La educación y difusión en seguridad de la información

Artículo 62 Implementación de la educación

1. El personal de seguridad de la información brinda educación en seguridad de la información a los nuevos usuarios al momento de unirse a la empresa, y a todos los usuarios con PC al menos una vez al año.
2. El personal de seguridad de la información impartirá formación a los usuarios que deban ser informados cuando exista un asunto de seguridad, configuración o cualquier otro que deba de informarse a los usuarios debido a una nueva introducción o cambio del sistema de información.
3. El supervisor del equipo se encargará de instruir y asegurarse de que sus subordinados cumplan con los contenidos de esta normativa.

Artículo 63 Implementación y educación de pruebas de seguridad

El personal de seguridad de la información realiza pruebas de seguridad, como entrenamiento de correo electrónico de ataques dirigidos, al menos una vez al año.

Artículo 64 Notificaciones a usuarios

El personal de seguridad de la información deberá publicar documentos relacionados mediante los medios adecuados para que los usuarios estén al tanto de esta norma, y en caso de producirse cambios, deberán notificarlos sin demora.

Capítulo 9 La subcontratación de sistemas de información

Artículo 65 Correspondencia con empresas subcontratadas.

1. Cuando el personal de seguridad de la información realiza un pedido a un proveedor externo para realizar trabajos relacionados con el sistema de información que maneja activos de información, debe asegurarse de que el proveedor comprenda, implemente y cumpla con los contenidos necesarios de la política de seguridad de la información y esta regla.
2. El personal de seguridad de la información intercambiará un acuerdo de confidencialidad con el proveedor externo.

Capítulo 10 Sanciones

Artículo 66 Sanción

1. Si un usuario viola esta regulación de manera intencional o por negligencia grave, o si el usuario comete una violación grave de seguridad de la información, el usuario estará sujeto a medidas disciplinarias de acuerdo con el artículo del ACUERDO DE ACCESO DE USUARIO/RECONOCIMIENTO DE RESPONSABILIDADES.
2. El usuario puede reclamar daños o ser demandado si causa daños a la empresa o actúa en violación de la ley.

Capítulo 11 Reglas de excepción

Artículo 67 Excepción

Si se presenta una situación en la que no se pueda cumplir con esta regla debido a razones comerciales, el usuario debe obtener la aprobación del oficial de seguridad de la información para aplicar la excepción.
Disposiciones complementarias

Artículo 68 Fecha de entrada en vigor

Esta regla entrará en vigor el 01 de mayo de 2023.